Analyse NIS2 / DORA

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans* `constat/etat-implementation.md`*.*

> *Ticket : WOR-69 · Responsable : Cédric · Version 0.3 du 22/10/2026*
>
> *Le sujet demande de* ***distinguer les exigences pertinentes des obligations qu'un prototype de quatre jours ne peut pas démontrer****. Pour chaque exigence, ce document dit donc ce que le démonstrateur prouve, et ce qu'il ne prouve pas.*

1. Quel texte s'applique ?

Question	Réponse	Fondement
Notre entreprise fictive est-elle dans le champ de DORA ?	**Oui.** Un opérateur de paiement est un établissement de paiement, explicitement visé.	DORA (règlement UE 2022/2554), art. 2.1 b. Applicable depuis le 17/01/2025.
Est-elle dans le champ de NIS2 ?	**Non.** Les établissements de paiement ne figurent pas à l'annexe I de NIS2, dont le secteur bancaire ne vise que les établissements de crédit.	NIS2 (directive UE 2022/2555), annexe I.
Si les deux s'appliquaient, lequel prime ?	**DORA.** C'est un acte sectoriel qui prévoit des mesures au moins équivalentes ; il remplace NIS2 pour la gestion du risque et la notification des incidents.	NIS2, art. 4 et considérant 28.
Qui est l'autorité compétente ?	L'**ACPR** pour un établissement de paiement en France.	Désignation nationale au titre de DORA.
Le cadre simplifié (art. 16) s'applique-t-il ?	**Non.** Avec 158 M€ de revenu annuel et 200 partenaires, l'entreprise n'est pas une petite structure exemptée.	DORA, art. 16.

Conclusion : on raisonne en DORA. NIS2 reste utile comme grille de lecture (mesures de l'art. 21, chaîne d'approvisionnement), mais ce n'est pas le texte qui nous oblige.

2. Ce que DORA exige, et ce que le démonstrateur prouve

✅ démontré · 🟡 démontré en partie · ❌ non démontrable en 4 jours. Les preuves seront confirmées par les essais (WOR-73).

2.1 Gestion du risque TIC (art. 5 à 16)

Exigence	Art.	Ce que le prototype montre (preuve)	Statut
Cadre de gestion du risque documenté, fonctions critiques identifiées	6, 8	EBIOS RM, services critiques chiffrés, biens supports reliés aux valeurs métier	✅
Protection : moindre privilège, secrets, filtrage	9	WAF bloquant, secrets du socle dans Vault, conteneurs durcis, moteur de remédiation encadré ; authentification forte du back-office (visage puis mot de passe, verrouillage après 2 échecs), comme le demande l'art. 9.4 d)	🟡 un seul hôte ; secrets de Pay&Go et port de sa base encore exposés

Exigence	Art.	Ce que le prototype montre (preuve)	Statut
Détection rapide des anomalies	10	Détection ML sur métriques et journaux ; délai attaque → alerte mesuré à l'essai	🟡 délai pas encore mesuré
Réponse et rétablissement	11	**Cœur de la démo** : remédiation automatique, puis transaction de test réussie ; durée comparée au RTO	🟡 RTO pas encore mesuré
Tests du plan de continuité	11.6	Scénarios rejoués et chronométrés	🟡 deux scénarios, pas de programme annuel
Sauvegarde et restauration sans perte	12	Comptage des transactions avant et après reprise	❌ aucune sauvegarde ; la restauration repart des données de départ
Redondance	12.4	—	❌ hôte unique, assumé
Retour d'expérience	13	Analyse après incident à partir des journaux, aidée par l'assistant RAG	🟡
Communication de crise	14	Plan de communication du PCA	🟡 sur papier
Responsabilité de la direction, formation	5	—	❌ pas de direction réelle

2.2 Gestion et notification des incidents (art. 17 à 23)

Exigence	Article	Ce que le prototype montre	Statut
Processus de détection, journalisation et suivi des incidents	17	Chaque incident est horodaté dans le journal du moteur de remédiation et visible au tableau de bord ; blocages du WAF dans le SIEM	🟡
Classification selon les critères réglementaires	18	Grille appliquée au scénario de la démo (voir section 3)	✅ sur papier, à partir des mesures réelles
Notification des incidents majeurs à l'ACPR : initiale, intermédiaire, finale	19	Les journaux du SIEM contiennent les informations nécessaires. Aucune notification réelle n'est envoyée.	🟡
Information des clients touchés	19.3	—	❌

2.3 Tests de résilience (art. 24 à 27)

Exigence	Article	Ce que le prototype montre	Statut
Programme de tests : analyses de vulnérabilités, tests de scénarios, tests de performance	24, 25	Scénario Red Team depuis le PC Attaquant, scans de vulnérabilités	🟡 un essai ponctuel, pas un programme
Tests d'intrusion fondés sur la menace (TLPT), tous les 3 ans, par des testeurs indépendants	26, 27	—	❌ réservé aux entités désignées, exige des testeurs externes

2.4 Risque lié aux prestataires TIC (art. 28 à 44)

Exigence	Article	Ce que le prototype montre	Statut
Registre des accords avec les prestataires TIC	28.3	Inventaire des briques utilisées (images Docker, Ollama, modèles)	🟡 inventaire technique, pas contractuel
Clauses contractuelles obligatoires, stratégies de sortie	28.8, 30	—	❌ aucun contrat

Exigence	Article	Ce que le prototype montre	Statut
Concentration du risque sur un prestataire	29	Tout est auto-hébergé, sauf l'assistant de discussion de l'application, qui appelle OpenAI	🟡 un prestataire externe à inscrire au registre, ou à remplacer par le modèle local (Ollama)

3. Le scénario de la démo est-il un incident majeur ?

DORA classe un incident comme **majeur** s'il touche un service critique et, en plus, soit entraîne une perte de données après un accès malveillant, soit dépasse les seuils d'au moins deux autres critères (règlement délégué (UE) 2024/1772). Les critères utiles ici :

- **Durée** : interruption d'un service critique de plus de 2 h (ou incident de plus de 24 h) ;
- **Clients touchés** : plus de 10 % des clients ou des contreparties financières ;
- **Impact économique** : plus de 100 k€ de coûts et pertes ;
- **Perte de données** : atteinte à la disponibilité, l'intégrité ou la confidentialité des données.

Appliqué au risque R1 (déni de service sur l'API, scénario principal), en heure de pointe et avec les 200 partenaires touchés :

Mode de reprise	Durée	Critères dépassés	Majeur ?	Conséquence
Automatique (cible de la démo)	≤ 5 min	Clients touchés	**Non**	Incident enregistré et classé, pas de notification
Manuelle	30 min à 2 h	Clients touchés, impact économique (pénalité SLA ~650 k€)	**Oui, probablement**	Notification initiale à l'ACPR, puis rapports intermédiaire et final
Manuelle, longue	> 2 h	Clients, durée, impact économique	**Oui**	Idem, et incident G4 dans EBIOS

> ***Attention :*** *le critère économique peut faire basculer l'incident en majeur **avant** le seuil de 2 h, dès que la pénalité SLA est déclenchée (43 min d'arrêt cumulé dans le mois).*
>
> ***Incidents récurrents :*** *des incidents qui ne sont pas majeurs un par un, mais qui ont la même cause apparente, se sont produits au moins deux fois en 6 mois et dépassent ensemble les seuils, sont traités comme un seul incident majeur (règlement délégué (UE) 2024/1772, art. 16). Des dénis de service courts et répétés peuvent donc finir par imposer une notification.*

Pour R2 et R5 (injection, exfiltration), le critère « perte de données après accès malveillant » suffit, avec la criticité du service, à rendre l'incident majeur, **quelle que soit la vitesse de reprise**. Restaurer la disponibilité ne dispense pas de notifier. C'est la distinction que le sujet demande de ne pas manquer.

Paradoxe du démonstrateur : la restauration actuelle efface toutes les transactions, et elle se déclenche même quand le WAF a bloqué l'injection (`constat/etat-implementation.md` §3). C'est alors notre propre remédiation qui crée la perte de données après une tentative malveillante, donc l'incident majeur. D'où la recommandation de ne restaurer que si une injection a passé le WAF.

Argument pour la direction : la reprise automatique en moins de 5 minutes n'est pas seulement un gain technique. Elle maintient un déni de service sous les seuils de DORA, ce qui évite la notification réglementaire et la pénalité contractuelle.

4. Ce que nous ne pouvons pas démontrer

Les limites du prototype face à DORA (hôte unique, sauvegardes, tests indépendants, contrats, direction, notification réelle) et ce qu'il faudrait en contexte industriel sont regroupées dans `recommandations.md` §3.